# Bonus items writeups

## Scale

When scaling comes into picture, it can be divided into two:

### Things that don't change:

- Policies as code
- Tenancy template: namespace + quota + limits + default-deny + RBAC + AppProject.
- Secure by default settings: cluster-wide default deny, namespace guard, image rules etc.
- Tier: Standard (runc with Falco), untrusted (gVisor)

### Things that change:

- **Control plane:**
  - Current:  just 1 node,
  - Should be: 3 or 5 (for quorum) with etcd on dedicated instance and encrypted snapshots stored in another location.
- **Tenant boundary:**
  - Current: it is one namespace per tenant and node is shared
  - Should be: Namespace for trusted teams, dedicated node pools (taints and Kyverno-enforced tolerations/nodeSelector) for untrusted workloads OR cluster per tenant virtual cluster or a dedicated cluster with Kata/gVisor for runtime isolation where tenants need cluster-admin or GPU isolation.
- **Identity:**
  - Current: Admin client cert
  - Should be: OIDC (per person, MFA), groups from the IdP maps the per-tenant RoleBindings and short-lived kubeconfigs.
- **Access:**
  - Current: SSH to control plane and ssh tunnel for kubectl
  - Should be: No public SSH instead have Tailscale/Teleport with audited sessions, and API behind private LB withIP allow-lists
- **Detection:**
  - Current: Prometheus with alerts on alertmanager ui
  - Should be: Falco/audit/Hubble events shipped to a central SIEM and detections as code with ci tests
- **Supply chain:**
  - Current: verifying signs
  - Should be: Internal registry (ex: Harbor) as the only allowed source, with scan and re-sign at ingestion. And kyverno verifies the platform key everywhere. Also SBOM attestations can be used.
- **Vuln mgmt:**
  - Current: Trivy operator per cluster

    - Should be: Centralisation of VulnerabilityReports, SLA tracking, CI gate on every tenant repo
- **GPU:**
    - Current: nothing 🙂
    - Should be: GPU nodes in dedicated pools, no MIG sharing across tenants unless the tier allows it, gVisor GPU support evaluated per driver.
- **runtime:**
    - Current: gvisor overhead per tenant
    - Should be: measueed with sandbox only for untrusted tier and keeping runc with falco for trusted workloads.
- **Policy rollout:**
    - Current: one cluster, new policies go in through a PR and start in Audit, then switch to Deny in a second PR.
    - Should be: ring rollout across the fleet with Argo CD ApplicationSets. Ring 0 is canary clusters in Audit mode. PolicyReports are reviewed there, then the policy moves to Enforce ring by ring (canary → non-prod → prod), with the policy version pinned per ring in Git. Kyverno is fail-closed, so it needs 3+ replicas and webhook alerts.
- **Break-glass:**
    - Current: admin cert on my laptop, always valid.
    - Should be: OIDC for daily work. The emergency credential is kept offline with two-person approval, short-lived, alerts on every use, and is rotated afterward.
- **Zero-downtime CNI upgrade:**
    - Current: Cilium pinned in the chart and is upgraded manually.
    - Should be: run the pre-flight check, upgrade one minor version at a time, in canary clusters first, node by node. The eBPF datapath keeps traffic flowing while the agent restarts, and a spike in Hubble drops is the rollback signal.

## Two small notes:

- Per-cluster Falco with Hubble metrics grows with tenants so they need to be aggregated centrally.
- Namespace-level isloation is not a hard boundary against kernel level attacks on shared nodes, that's why added gVisor tier but dedicated node pools can also be used for sensitive tenants.

# Attack scenarios

## Two scenarios:

**Scenario 1:  RCE in a tenant app -> credentials theft -> lateral movement**

Attacker has code execution in demo/frontend

| Step | Attempt | Control | Result | Detection |
|---|---|---|---|---|
| 1 | Interactive shell | allowed: it is the foothold | Shell runs | ShellSpawnedInContainer(critical) |
| 2 | Read SA token from /var/run/secrets | Kyverno: automountServiceAccountToken: false | No token in pod | |
| 3 | Cloud metadata 169.254.169.254 | Cilium cluster-wide egress deny | Dropped | Hubble drop, NetworkPolicyDropsSpike |
| 4 | Kubelet :10250/pods on a node | Cilium cluster-wide egress deny | Dropped | Hubble drop |
| 5 | API server 10.43.0.1:443 | Default-deny (tenant and cluster-wide) | Dropped | Hubble drop; Falco API rule as backup |
| 6 | Pivot to tenant-b | Default-deny both sides | Dropped | Hubble drop |
| 7 | Write a tool to disk | Read-only root FS | Fails | |

**Scenario 2: Malicious tenant / poisoned supply chain**
Attacker is a tenant developer (or controls a commit to a tenant path, or a registry account).

| Step | Attempt | Control | Result |
|---|---|---|---|
| 1 | Privileged pod / hostPath | PSA restricted with Kyverno PSS | Denied (PSA first, Kyverno second) |
| 2 | Untrusted registry, :latest | Kyverno allow-list, tag rule | Denied |
| 3 | Image from an allow-listed publisher but unsigned / tampered | Kyverno verify-image-signatures (pinned keyless identity) | Denied |
| 4 | Drop gVisor in the | Kyverno require-sandbox | Denied |

| | | | |
|---|---|---|---|
| | untrusted tier | | |
| 5 | Relax own namespace (PSA privileged, remove sandbox label) | RBAC (no namespace rights) and Kyverno namespace-guard | Denied |
| 6 | Delete own default-deny / grant self RBAC | RBAC tenant-developer (no netpol/RBAC verbs) with AppProject blacklist | Denied |
| 7 | Deploy into another tenant via Argo CD | AppProject destination is own namespace only | Refused |
| 8 | Kernel exploit from untrusted code | gVisor (user-space kernel) for tenant-b | Contained in sandbox, Falco blind inside gVisor |

# CVE triage

1. **Prioritisation**: questions I will check:
    - Is vulnerable path reachable?
    - Is it exposed?
    - Is exploit available (can be checked in CISA KEV)?
    - Impact?
    - Any controls available to contain?
2. **Fix**:
    - Release that can fix should be atleast 2 weeks old.
    - Verifying it with cosign verify
    - Pin it by digest in manifest
    - Verification on running workload
3. **Example (present in repo)**:
    - Image: podinfo:6.8.0 (tenant demo backend)
    - Findings: 6 critical, but fix were available ( Go stdlib CVE-2025-68121, OpenSSL CVE-2026-31789)
    - Fix using the patches (podinfo:6.15.0).
    - Contained: non-root, RO FS, no token, default-deny